

AATA COMPONENT AND TOOLING SPECIFICATION

Part II of the Autonomous Agent Trust Architecture

*Overlay Components, Reference Tool Stacks, Build/Adopt Dispositions, and Differentiated IP
Register*

Version 1.0 | July 2026

Protime Consulting Inc. — Companion to AATA-2026-001

Table of Contents

Table of Contents.....	2
1. The Overlay Thesis	3
2. Overlay Component Architecture.....	3
3. Control-to-Component Traceability.....	6
4. Reference Tool Stacks by Footprint	7
5. DDIL Mechanics per Component.....	8
6. Differentiated IP Register	8
7. MVP Composition Sequence.....	9

1. The Overlay Thesis

AATA deploys as an **overlay** — a security and governance mesh inserted around an existing agent estate without rewriting the agents. This is the agentic overlay deployment pattern, generalized. The estate (LLM applications, orchestrated workflows, embodied platforms, tools, and data) remains unmodified; the overlay owns three insertion points that together see and gate everything that matters:

- **Traffic interception.** Every LLM inference call and every tool/actuator invocation transits the Agent Gateway (the Policy Enforcement Point). Agents never hold direct credentials to tools; the gateway holds them and releases access per-verdict.
- **Identity injection.** A per-node identity sidecar issues and rotates workload identities, and verifies signed model artifacts before the local runtime loads them.
- **Runtime observation.** An eBPF sensor layer watches agent process behavior beneath the application — syscalls, network flows, file access — providing ground truth that a compromised agent cannot falsify from inside its own context window.

Everything else — PDP, capability tokens, hygiene, evidence pipeline, analytics, governance console — consumes these three insertion points. The consequence: **AATA can wrap any agent framework** (LangGraph, AutoGen, CrewAI, custom orchestrators, OpenClaw, vendor copilots) because it standardizes at the traffic, identity, and kernel layers rather than the framework layer.

2. Overlay Component Architecture

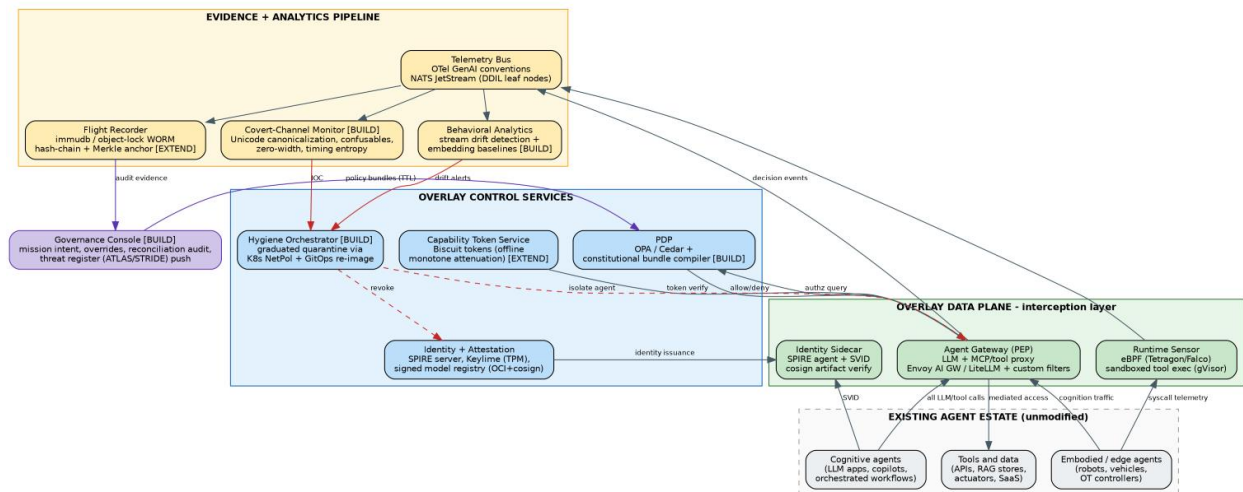


Figure 4 — Overlay component architecture. Green = data plane interception; blue = control services; amber = evidence pipeline; purple = governance. [BUILD]/[EXTEND] tags mark differentiated components.

Twelve components constitute the overlay. Each carries a disposition: ADOPT (off-shelf, configure only), EXTEND (off-shelf core plus custom modules), or BUILD (differentiated IP — no adequate tooling exists).

Component	Disposition	Tooling	Function / notes
C1. Agent Gateway (PEP)	EXTEND	Envoy AI Gateway or LiteLLM proxy core; custom MCP gateway filters for tool mediation, context provenance tagging, canonicalization pre-pass	Single choke point for all inference and tool traffic; enforces PDP verdicts; emits decision events
C2. Identity Sidecar	ADOPT	SPIRE agent (SPIFFE runtime); cosign verification of model/skill artifacts at load	Per-node SVID issuance and rotation; artifact signature gate
C3. Runtime Sensor	ADOPT	Tetragon or Falco (eBPF); gVisor/Kata sandboxes for tool execution	Kernel-level ground truth; sandboxed blast radius for tool calls
C4. Identity + Attestation Service	EXTEND	SPIRE server (nested topology for DDIL); Keylime for TPM attestation; OCI registry + cosign as signed model registry; custom weights/prompt-digest attestor plugin	AATA-TR-01/02; model hash attestation is the custom plugin — SPIRE attests platforms, not weights, out of the box
C5. Capability Token Service	EXTEND	Biscuit tokens (native offline monotone attenuation) or Macaroons; custom semantics layer for tool classes, actuation classes, spend ceilings, delegation depth	AATA-TR-03; Biscuit's offline attenuation is the exact primitive for sub-agent capability subsetting in DDIL
C6. Policy Decision Point	EXTEND	OPA (Rego) or AWS Cedar engine; OPA bundle API with TTL for policy distribution; custom constitutional compiler translating governance policy to Rego/Cedar	AATA-CT-01/GV-01; bundle-TTL model natively implements Degraded-mode policy caching
C7. Hygiene Orchestrator	BUILD	Custom service driving: K8s NetworkPolicy isolation, SPIRE credential revocation, Biscuit revocation lists, GitOps (Argo CD/Flux) golden re-image, forensic state preservation	AATA-CT-02; graduated-response state machine for agents does not exist off-shelf — core IP
C8. Telemetry Bus	ADOPT	OpenTelemetry with GenAI semantic conventions; NATS JetStream (leaf-node model) or Kafka	NATS leaf nodes give native store-and-forward for Degraded/Isolated sites
C9. Flight Recorder	EXTEND	immudb or S3 Object-Lock WORM store; custom hash-chain writer with periodic external Merkle anchoring; pre-actuation write hook in C1	AATA-OB-01; the pre-actuation ordering guarantee is the custom part
C10. Covert-Channel Monitor	BUILD	Custom: ICU-based Unicode canonicalization (NFKC), confusables and zero-width detection, semantic drift scoring, timing-entropy analysis on tool-call cadence	AATA-OB-02; no commercial tool inspects inter-agent steganography — flagship differentiator
C11. Behavioral Analytics	BUILD	Stream processing (Flink/Faust) over C8; embedding-space baselines (Voyage-class embedding models) per agent role; fleet-level distribution drift (tool-use, token economics, delegation graphs)	AATA-OB-03; agent-native UEBA does not exist — second differentiator

Component	Disposition	Tooling	Function / notes
C12. Governance Console	BUILD	Custom: mission intent authoring, override/escalation UI, reconciliation audit workflow, threat-register (ATLAS/STRIDE) push to C6/C10 detection logic	AATA-GV-01/02/03; the human authority surface, incl. Isolated-mode post-hoc audit

3. Control-to-Component Traceability

Every AATA control from Part I, Section 8 resolves to overlay components. This is the matrix that converts the framework into a backlog.

Control	Control name	Component(s)	Implementation note
AATA-GV-01	Signed constitutional policy store w/ TTL	C12 → C6	Console authors and signs; constitutional compiler emits Rego/Cedar bundles with TTL
AATA-GV-02	Human authority interface + reconciliation audit	C12	Override actions themselves logged to C9 (auditors are audited)
AATA-TR-01	Per-agent hardware-rooted identity	C2, C4	SPIRE node attestation chained to Keylime TPM evidence
AATA-TR-02	Model + runtime attestation	C4	Custom attester plugin: weights/adapters/prompt digests vs signed OCI manifest
AATA-TR-03	Scoped capability tokens, monotone attenuation	C5, C1	Biscuit attenuation at sub-agent spawn; gateway verifies full chain
AATA-CT-01	PDP gating; fail-closed kinetic	C6, C1	Actuation classes carry fail-closed flag; gateway defaults deny on PDP timeout for kinetic
AATA-CT-02	Autonomous hygiene / golden re-image	C7	Graduated ladder: narrow token → isolate NetPol → revoke SVID → wipe → GitOps rebuild
AATA-CT-03	Tiered model routing	C1	LiteLLM router policies; 4-tier model routing pattern as reference config
AATA-OB-01	Hash-chained pre-actuation flight recorder	C9, C1	Gateway blocks actuation until recorder write acknowledged
AATA-OB-02	Covert-channel monitoring	C10, C1	Canonicalization pre-pass at gateway; deep inspection async on bus
AATA-OB-03	Behavioral baselining / fleet anomalies	C11	Baselines per agent role; alerts drive C7 graduated response
AATA-EX-01	Mediated tool proxies	C1, C3	MCP gateway pattern; tool exec in gVisor sandboxes
AATA-EX-02	Reflex-layer safety interlocks	Estate + C3	Embodied: ROS 2/SROS2 with safety PLC channel independent of cognition; C3 observes only
AATA-DD-01	Defined DDIL behavior per control	All	See Section 5 — DDIL mechanics per component

4. Reference Tool Stacks by Footprint

Concrete, named stacks per deployment footprint. F1 maps to a managed-cloud estate (Azure shown, given typical enterprise/federal alignment); F2 and F3 are cloud-independent.

Layer	F1 Enterprise (Azure)	F2 Sovereign Edge	F3 Isolated Autonomy
Gateway / PEP	APIM + Envoy AI GW filters; LiteLLM router	Envoy AI GW on K8s (RKE2/OpenShift); LiteLLM	Embedded LiteLLM-class proxy in-process
Identity	Entra Workload ID federated to SPIRE; MAA for attestation	SPIRE (nested) + Keylime TPM	Embedded SPIRE agent; peer mesh mTLS; pre-provisioned trust bundle
Model registry	ACR + cosign; signed prompt/adaptor manifests	Harbor (OCI) + cosign; air-gap replication	Local signed store; updates via signed physical media / burst sync
PDP / policy	OPA bundles from Console; Azure Policy for infra	OPA/Cedar local; bundle TTL 24–72h	Compiled constitutional constraints on-agent; Cedar embedded; TTL = mission duration
Inference	Azure OpenAI/Anthropic APIs + AKS vLLM burst	vLLM / TensorRT-LLM on H200 cluster; KServe	Orin-class on-device (Gemma/Haiku-tier local models)
Telemetry	OTel → Event Hubs → Sentinel + ADX	OTel → NATS JetStream → ClickHouse	OTel → local JetStream leaf; store-and-forward
Flight recorder	Immutable Blob (legal hold) + hash-chain anchor	immudb; periodic external Merkle anchor	SQLite hash-chain ledger; reconciliation on reconnect
Runtime security	Defender for Containers + Tetragon	Tetragon/Falco; gVisor sandboxes	Minimal eBPF sensor profile; watchdog co-processor
Hygiene actions	AKS NetPol + Entra revocation + Argo CD	K8s NetPol + SPIRE revoke + Flux golden images	Peer-mesh voting quarantine; local re-image from golden partition
SIEM/SOC surface	Sentinel analytic rules from ATLAS register	Wazuh/Elastic or client SIEM integration	Deferred: reconciliation ledger replay on reconnect

5. DDIL Mechanics per Component

The tooling choices above were selected specifically because each has a native offline or disconnected mode. This is the design filter most stacks fail.

- **OPA bundle TTL (C6):** policy bundles are pulled and cached with expiry; Degraded mode extends TTL under signed degradation rules; Isolated mode ships mission-duration bundles compiled to on-agent constraints.
- **Biscuit offline attenuation (C5):** sub-agent capability subsetting requires no callback to the token service — attenuation is cryptographic and verifiable locally. Revocation lists sync opportunistically.
- **SPIRE nested topology (C4):** downstream SPIRE servers at edge sites issue identities autonomously against a pre-established upstream trust bundle; Isolated mode substitutes the peer-attestation mesh with quorum verification.
- **NATS JetStream leaf nodes (C8):** evidence streams persist locally and replay upstream on reconnect — store-and-forward is the default behavior, not an exception path.
- **GitOps golden re-image (C7):** golden baselines are content-addressed and locally cached; re-image works air-gapped from the local registry mirror or golden partition.
- **Reconciliation ledger (C9):** Isolated-mode decisions accrue with hash-chain continuity; on reconnect, replay to the flight recorder plus human review queue in the Governance Console (C12) closes the audit loop.

6. Differentiated IP Register

The BUILD components are the product roadmap — the layer no vendor ships and every autonomous-fleet operator will need.

IP asset	What it is	Provenance / head start
Covert-Channel Monitor	Inter-agent steganography detection: Unicode confusables/zero-width channels, semantic drift, timing-entropy on tool-call cadence	Codified from covert-channel threat modeling; publishable + ATLAS contribution candidate
Hygiene Orchestrator	Graduated autonomous response state machine for agent fleets (narrow → isolate → revoke → wipe → rebuild) with forensic preservation	Agentic overlay self-hygiene threat modeling; agentic red-team findings as test cases
Constitutional Compiler	Governance policy → enforceable Rego/Cedar bundles and on-agent compiled constraints (Isolated mode)	ITP / Bounded ITP research as the theory base
Agent-native Behavioral Analytics	UEBA for agents: role-conditioned embedding baselines, delegation-graph anomalies, token-economics drift	OpenClaw token-economics instrumentation as reference data
Model Attestation Plugin	SPIRE attester extension covering weights/adapters/prompts digests against signed manifests	H200 platform model-registry design

IP asset	What it is	Provenance / head start
Governance Console	Mission intent, override, reconciliation audit, threat-register push — the human authority surface	Agentic overlay stakeholder workflow patterns

7. MVP Composition Sequence

Minimum path to a working overlay on an existing estate — each step independently valuable, ordered by dependency:

- **Step 1 — See (weeks 1–4):** C1 gateway in observe-only mode + C8 bus + C9 recorder. Zero enforcement risk; immediate evidence and visibility. Deliverable: full decision-trail of the existing estate.
- **Step 2 — Gate (weeks 4–10):** C6 PDP with permissive-then-enforcing policy; C5 capability tokens for the top-10 tools; fail-closed on any kinetic/irreversible class.
- **Step 3 — Prove (weeks 8–14):** C2/C4 identity and model attestation; signed model registry; block unattested artifact loads.
- **Step 4 — Watch (weeks 12–20):** C10 covert-channel monitor + C11 behavioral baselines over the evidence accumulated since Step 1.
- **Step 5 — Heal (weeks 18–26):** C7 hygiene orchestrator, tabletop-tested against the Part I threat register, then armed for autonomous graduated response.
- **Step 6 — Degrade gracefully (weeks 24+):** DDIL certification: TTL policy drills, store-and-forward failover, reconciliation-ledger audit exercise.

Steps 1–2 alone constitute a fundable engagement and a demonstrable product wedge; Steps 4–5 are where the differentiated IP compounds.